7-ELEVEN ATTACK ANALYSIS

When Trust Is the Vulnerability

The 2026 7-Eleven franchisee data breach & the ShinyHunters Salesforce campaign — three candidate vectors, weighed

STRIDE | OWASP Threat Dragon | CVSS v4.0 | CWE · CAPEC · ATT&CK

Methodology-driven investigation · threat model · root cause · severity · controls · detection

Prepared by: Harjot Sidhu & Mehakpreet Thind · Revised 10 August 2026

ROADMAP

What we'll cover

1



Refined attack analysis

Overview, timeline and two technical flows

2



Updated threat model

STRIDE rebuilt — and what changed since the midterm

3



Root cause & vulnerability analysis

NVD search, CVE status, CWE / CAPEC / ATT&CK

4



Severity & impact analysis

CVSS v4.0, business impact, exploitability

5



Mitigation & defense strategies

Existing patches, gaps, proposed improvements

6



Original insights

Four evidenced findings of our own

7



Aftermath & sources

Response, litigation, references

ATTACK OVERVIEW

The incident at a glance

7-Eleven, Inc.

Convenience retail · franchise model

Discovered on **April 8, 2026** that an unauthorized third party accessed systems holding **franchisee application documents**. Names, dates of birth, addresses, phone numbers and e-mail addresses were exposed; the Massachusetts filing also confirms Social Security and driver's-license numbers.

Response: engaged a forensic security firm, notified law enforcement, remediated the incident and offered 24 months of IDX identity-theft protection and CyberScan monitoring (enrollment closed 1 Aug 2026). Notice signed by CISO Jim Kastle.

Sources: ME AG filing; BleepingComputer; Cyber Dive; Cybernews

Apr 8, 2026

Unauthorized access discovered

185,300

Unique e-mail addresses (HIBP)

600,000+

Salesforce records claimed by attacker

SSN + DL

Confirmed in the Massachusetts filing

9.4 GB leaked — after 7-Eleven refused to pay, ShinyHunters dumped the stolen archive on its dark-web site.

7-Eleven confirms no total: ~50 residents in ME/MA/VT filings; HIBP counts 185,300 e-mail addresses.

THE CENTRAL FINDING

No software was exploited. Trust was.

Salesforce and Google / Mandiant agree: no vulnerability in the Salesforce platform was involved. Salesforce attributes the 2026 wave to customer-configured Experience Cloud guest-user settings, and the 2025 wave to voice phishing and OAuth consent abuse. Either way the failure is configuration and trust — not code.

No CVE to patch

Vulnerability management never triggers

No exploit to signature

IDS / IPS / WAF see authenticated API calls

No credential to steal

Passwords and MFA are never in the attack path

ORIGIN & ATTRIBUTION

Who is behind it

ShinyHunters — a financially-motivated extortion collective that claimed 7-Eleven on 17–18 April 2026, set a 21 April deadline, and leaked the archive when the company refused to pay.

UNC6040

Initial access · 2025

Vishing → device-code OAuth grant

UNC6240

Extortion

“Pay-or-leak” demand, paid in Bitcoin

UNC6661 / 6671

Initial access · 2026

Renewed vishing against SSO, SharePoint and OneDrive

Not officially confirmed by 7-Eleven. Attribution rests on the group’s own claim plus researcher analysis. GTIG / Mandiant track UNC6040 (2025 access), UNC6661 / UNC6671 (2026 access) and UNC6240 (extortion); which cluster applies to 7-Eleven was never established.

ANALYTIC ASSESSMENT

Possible attack vectors & how we weigh them

7-Eleven has never disclosed the vector. Our chain is inferred from campaign reporting and from the companies 7-Eleven was grouped with on the leak site, so we carry three hypotheses rather than one certainty.

A · Guest-user abuse

Assessed most likely

Misconfigured Experience Cloud guest profile queried via /s/sfsites/aura — the vector Salesforce flagged in March 2026

B · Vishing + OAuth

Possible

Device-code consent phishing and a rogue Data Loader — the documented 2025 UNC6040 playbook

C · Third-party vendor

Cannot be excluded

7-Eleven says only “internal systems”; press reporting points to a franchise recruitment platform

Why A leads: on 18 April ShinyHunters listed 7-Eleven alongside Canada Life, Pitney Bowes, Marcus & Millichap and Aman Resorts — all named as hit through their Salesforce instances during the guest-user “Aura” wave. Salesforce declined to comment and 7-Eleven has confirmed nothing, so our confidence is low-to-moderate.

ATTACK VECTOR · HYPOTHESIS A

Chain A — Experience Cloud guest-user abuse (most likely)

A — Find the door

1 — Mass scanning

A weaponized AuraInspector sweeps public-facing Experience Cloud sites

2 — Guest profile enumerated

Objects and fields exposed to the anonymous guest user are cataloged

B — Open the door

3 — Unauthenticated API query

Records pulled through the /s/sfsites/aura endpoint — no login, no token, no MFA

4 — Query-limit bypass

A GraphQL path defeats the ~2,000-record guest cap, enabling bulk pulls

C — Take & extort

5 — Bulk exfiltration

Franchise-application records copied out at scale

6 — Pay-or-leak

Bitcoin demand with a 21 April deadline → the 9.4 GB dump

ATTACK VECTOR · HYPOTHESIS B

Chain B — vishing → device-code OAuth (the 2025 playbook)

A — Gain trust

1 **Reconnaissance**
Profile the org; find staff with CRM access

2 **Vishing call**
Impersonate IT support; manufacture urgency

B — Get the token

3 **Device-code OAuth grant**
Employee enters an attacker code on Salesforce's verify page → token to the attacker's Data Loader

4 **Over-permissioned app**
Rogue Data Loader gets broad API scopes (full read / export)

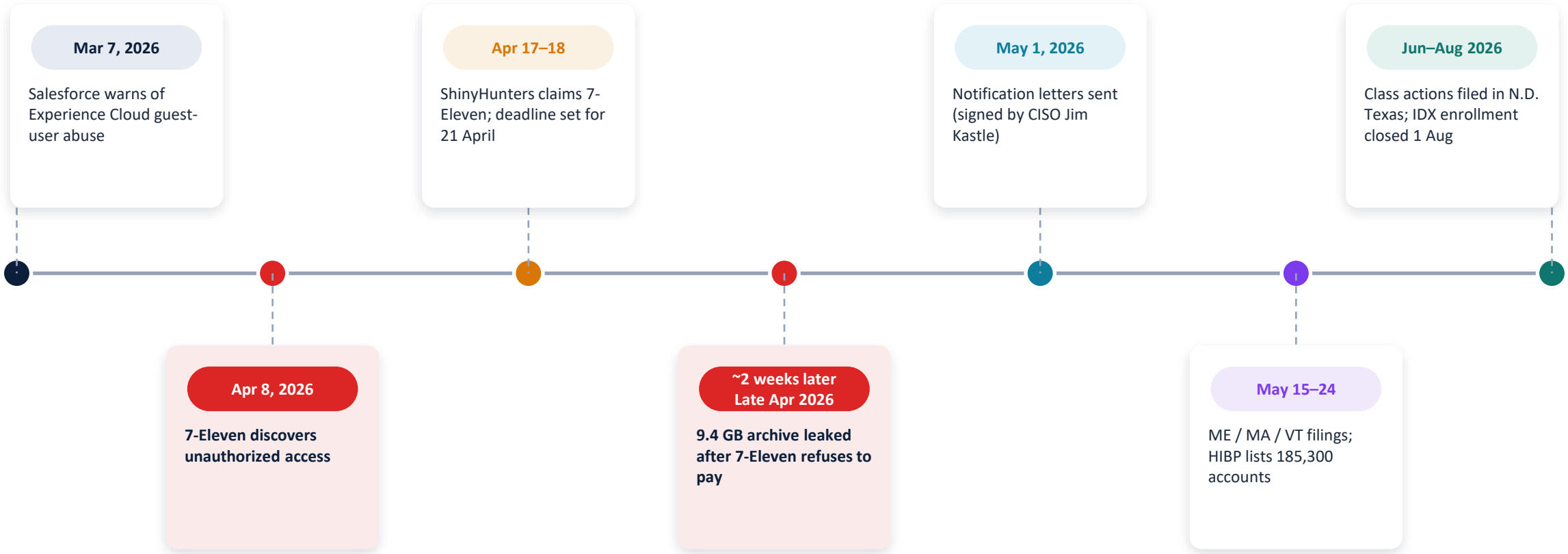
C — Take & extort

5 **Bulk exfiltration**
Query and export the franchisee / CRM data

6 **Extortion & leak**
Days later: Bitcoin demand + leak threat → the 9.4 GB dump

CURRENT STATE

How it unfolded



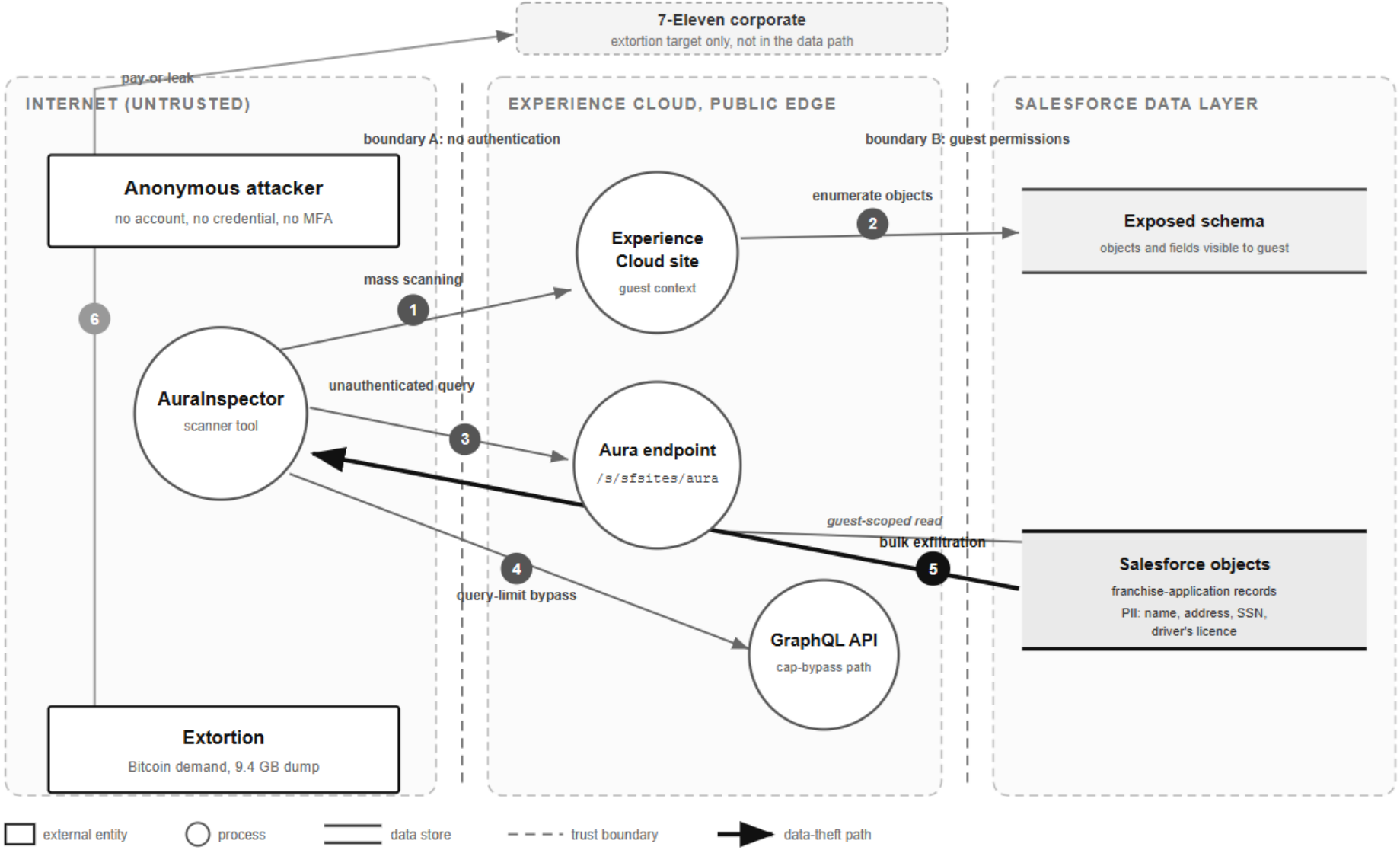
April 8 is the only date 7-Eleven states. The rest is reconstructed from regulatory filings, the HIBP listing, court records and the attacker's own claim.

UPDATED THREAT MODEL

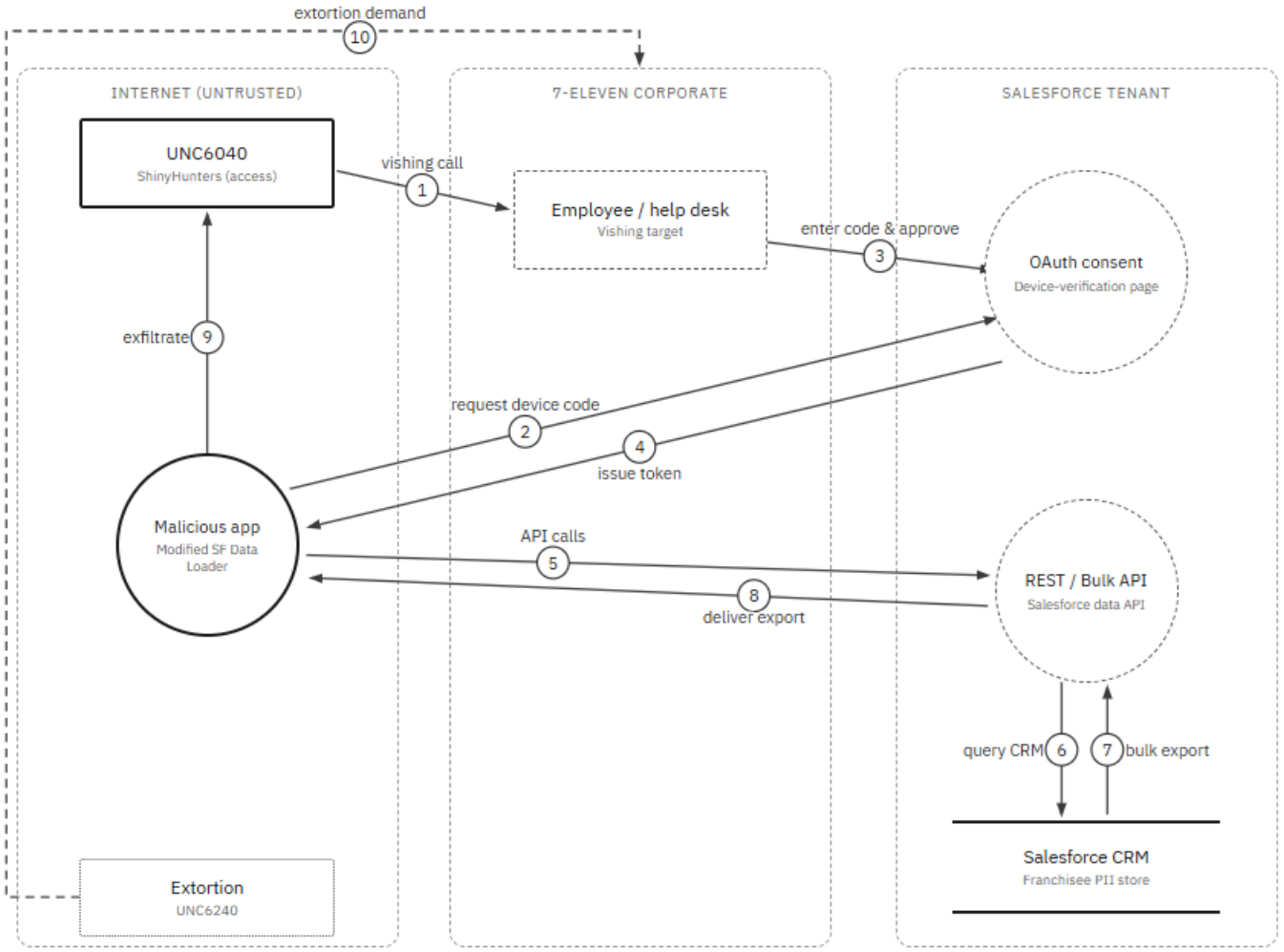
What changed since the midterm

The attack chain	We asserted the 2025 vishing / OAuth chain as fact. Salesforce attributes the 2026 wave to Experience Cloud guest-user misconfiguration, so we now carry three hypotheses with stated confidence.
Threat-actor clusters	UNC6040 is the 2025 access cluster. GTIG tracks 2026 vishing as UNC6661 / UNC6671; UNC6240 remains correct for extortion.
STRIDE ratings	Our ratings were keyed to Chain B only. Under Chain A, Spoofing falls away and the weakness moves to Missing Authorization at the guest-user boundary. Information Disclosure stays Critical either way.
Scope of the numbers	185,300 is HIBP's count of unique e-mail addresses, not confirmed people; the state filings count only ~50 in-state residents; 600,000+ remains an unverified attacker claim.

STRIDE data-flow model — Chain A



STRIDE data-flow model — Chain B



Assets

Franchisee CRM PII (names, addresses, SSN, DL); OAuth access token; audit logs

Threat actors

UNC6040 / UNC6661 access; UNC6240 extortion

Entry points

Help-desk employee (social engineering target); OAuth device-code verification page

Trust boundaries

Internet ↔ 7-Eleven Corporate ↔ Salesforce Tenant; OAuth token crosses tenant boundary

THREAT MODELING

STRIDE threats & the most critical risk

S — Spoofing

Vishing (IT-support impersonation); rogue Data Loader via device-code grant

High

T — Tampering

Not observed — the objective was data theft, not modification

Low

R — Repudiation

No IP restriction or export alerting to attribute the activity

Medium

I — Information Disclosure

Bulk export of regulated PII over an attacker-authorized token

CRITICAL

D — Denial of Service

Out of scope — objective is theft, not disruption

Low

E — Elevation of Privilege

Approval proves possession of a code, not identity; app over-scoped

High

Most critical risk: bulk export rides a legitimate, attacker-authorized token — it bypasses perimeter and password defenses, no least-privilege or IP restriction stops it, and it is irreversible once the data leaves. Under Chain A, Spoofing falls away and the failure sits in Missing Authorization at the guest-user boundary.

We searched NVD. There is no CVE.

What we searched: NVD keyword and CPE queries across Salesforce, Experience Cloud, Aura and guest user for Sept 2025 – Aug 2026. No CVE covers this campaign. CVE identifiers describe defects in a product; a tenant's own permission configuration falls outside every CNA's scope, so no identifier can exist.

Not in NVD

No CVE, no CPE, no NVD base score for the vector

Not in CISA KEV

No KEV entry, therefore no federal remediation deadline

No patch to apply

Remediation is a tenant setting, not a version upgrade

What NVD does hold for this ecosystem

CVE-2026-1731	BeyondTrust Remote Support / PRA pre-auth RCE, disclosed 6 Feb 2026. NVD lists CVSS v3.1 base 9.8 Critical and CWE-78 (OS command injection); added to CISA KEV on 13 Feb with a 16 Feb federal due date. BeyondTrust integrates with Salesforce.
CVE-2024-12356 / -12686	Earlier BeyondTrust zero-days used by Silk Typhoon in the 2024 US Treasury intrusion. Rapid7 showed exploitation required chaining CVE-2025-1094, a SQL-injection flaw in an underlying PostgreSQL tool.
Why they belong here	They are the counterfactual. A genuine product defect earns an NVD entry, a CVSS score, a KEV listing and a vendor patch inside seven days. Our incident earns none of the four — and that asymmetry is itself the finding.
So we map to CWE	With no product defect to identify, the underlying weakness has to be expressed as CWE classes and the behavior as CAPEC and ATT&CK — the next two slides.

ROOT CAUSE

No CVE — so we map to CWE

The CVE / NVD system catalogs software defects. There is no software defect here, so the weakness is expressed as CWE categories:

CWE-1390

Weak Authentication

Chain B primary — approval proved a code, not the requester's identity

CWE-732

Incorrect Permission Assignment

Chain A primary — guest profile could read non-public objects

CWE-269

Improper Privilege Management

Connected app received excessive OAuth scopes

CWE-862

Missing Authorization

No secondary control gated the bulk export

CWE-522

Insufficiently Protected Credentials

The OAuth token is a durable credential, handed over

Root cause

Misplaced trust, not a code defect

Authorization granted to the wrong party — by a person or by configuration

CWE describes software weaknesses only: the adversary behavior is mapped separately on the next slide. MITRE has not assigned any of these identifiers to the 7-Eleven incident — this is our own analytical mapping.

ATTACK PATTERNS

Mapping the behavior — CAPEC & MITRE ATT&CK

CAPEC-407 / 413 / 415

Pretexting → via tech support → via phone (vishing)

T1566.004

Spearphishing Voice — the Chain B entry point

T1528

Steal Application Access Token — consent / device-code

T1550.001

Use Alternate Authentication Material: App Access Token

T1213.004

Data from Information Repositories: CRM Software

T1657

Financial Theft — the UNC6240 pay-or-leak demand

Chain A maps differently: CAPEC-1 (functionality not constrained by ACLs) and CAPEC-180 (incorrectly configured access control), preceded by T1595 Active Scanning and followed by the same collection and exfiltration steps. Our mapping, not a MITRE assignment.

SEVERITY

CVSS v4.0

Base metric selections

AV Network	**AC** Low	**AT** None
PR None	**UI** Active / None	**VC** High
VI None	**VA** None	**SC** None
SI None	**SA** None	



CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:A/VC:H/VI:N/VA:N/SC:N/SI:N/SA:N

AV : Network

Exploited over the Salesforce API / OAuth endpoints

PR : None

Attacker rides the app's delegated identity — holds no account

VC : High

Full export of regulated CRM records (names, SSN, DL)

VI / SC : None

Pure exfiltration — no data modified, no documented downstream-system compromise

SEVERITY & IMPACT

Business impact and exploitability

Who actually bears it

Franchise applicants — not store customers

Direct cost: **24 months of IDX monitoring** for every notified individual, a forensic engagement, filings in three states, and defense of **consolidated class actions**. Indirect: the exposed population is people who applied to invest in the brand, so the damage lands on franchise recruitment itself.

Exploitability: Under Chain A no credential, no token and no user interaction are required — a single unauthenticated POST to /s/sfsites/aura. The tooling is automated and internet-wide, which is how one operator reached 300–400 organizations.

Sources: HIBP; MA AG filing; Salesforce; Top Class Actions

185,300

Records published — irrecoverable

9.4 GB

Archive live on the leak site

300–400

Organizations claimed in the same wave

2+

Class actions, N.D. Texas

No integrity or availability impact — but the confidentiality loss is permanent. An SSN or license number cannot be rotated like a password.

MITIGATION · WHAT ALREADY EXISTS

Existing solutions and patches

Salesforce — platform side	Closed the sortBy bypass of the 2,000-record guest query limit shortly before the 7 March advisory, and hardened the Aura endpoint — while maintaining that no platform vulnerability exists.
Salesforce — customer guidance	Advisories of 7 and 12 March 2026: uncheck API Enabled on the guest profile, set org-wide defaults to Private, restrict portal and site user visibility, disable self-registration.
Microsoft — 13 July 2026	Defender for Cloud Apps gained near-real-time Salesforce telemetry with connected-app attribution, 0–100 OAuth app risk scores, a highly privileged app view, and detection of apps unused for 90+ days.
Detection content and IOCs	Microsoft published campaign infrastructure, including two IPs used against Aura guest access on 19–22 June 2026, plus new Defender for Identity alerts for OAuth token abuse.

MITIGATION · WHERE IT FALLS SHORT

Limitations and gaps in the current defences

Patch, then re-bypass

The group says it found a second route around the record limit after Salesforce closed sortBy

Every fix is opt-in

Advisories are guidance; nothing compels a misconfigured tenant to change a setting

Telemetry costs extra

Full coverage needs Salesforce Shield Event Monitoring, which many tenants do not license

Scanning ≠ compromise

Mandiant notes that scanning in your logs does not confirm a breach, so triage stays ambiguous

Vendor sprawl

Each new integration reopens the path — Drift, Gainsight and Klue inside twelve months

No KEV, no clock

With no CVE there is no regulatory deadline forcing anyone to remediate

The structural gap: Every control here belongs to the customer, while the vendor's public position is that nothing is broken. That combination leaves a governance problem with no patch cycle attached to it, and with no external body measuring whether anyone was compliant.

MITIGATION · PROPOSED IMPROVEMENTS

Controls that would have broken the chain

Lock down guest users

Uncheck API Enabled on the guest profile; org-wide defaults Private

Connected-app allow-listing

Approve only vetted apps; block unmanaged Data Loader clones

Least-privilege scopes

No single authorization should export a whole object

IP and location binding

Constrain where issued tokens and sessions may be used

Bulk-export detection

Alert on API volume, ReportExport and guest-user API calls

Data minimization

Encrypt or redact SSN / DL; retire application files on a schedule

Plus anti-vishing verification: A defined out-of-band call-back before any employee approves an authorization code (ATT&CK M1017 training, M1018 account management, M1047 audit). Data minimization is the control the class actions allege was missing.

ORIGINAL INSIGHTS

Our Findings

Each insight is evidenced and dated. We went looking for the four things the brief names: public exploit code, evidence of exploitation in the wild, detection gaps in security tooling, and propagation across products.

1 · Dual-use tooling

Public exploit code

Mandiant shipped AuraInspector on 12 Jan 2026 to help admins find exposure; ShinyHunters reworked it into an extraction engine

2 · Patched, re-bypassed

Vendor fix vs. actor

Salesforce closed the sortBy record-limit bypass; the group says it found a second route within days

3 · The CVE blind spot

Detection gap

No CVE means no NVD score, no KEV clock and no scanner signature — the whole pipeline misses it

Measured against a real CVE: BeyondTrust's CVE-2026-1731 went from disclosure on 6 Feb to an NVD score to a CISA KEV listing on 13 Feb — seven days — with GreyNoise observing scanning surges. Our campaign has run since Sept 2025 across 300–400 organizations and produced none of those artifacts.

ORIGINAL INSIGHTS · FINDING 4

Propagation across the OAuth trust graph

Salesloft Drift

Aug 2025 · stolen OAuth tokens · ~760 downstream orgs

Gainsight

Nov 2025 · connected-app token abuse · 200+ instances

Klue

Jun 2026 · Storm-3138 · vendor credentials reused into tenants

Aura guest access

Sept 2025 onward · 300–400 orgs · no vendor required

Anodot

Apr 2026 · stolen tokens reach Google BigQuery

UNC6661 / UNC6671

Jan 2026 · vishing against SSO, SharePoint and OneDrive

The pattern: one vendor compromise propagates to every tenant that trusted it, and the trust survives the vendor's own remediation because the grant lives in the customer's org, not the vendor's. Microsoft tracked this tradecraft across many tenants in retail, education and manufacturing over twelve months.

RESPONSE

Response, remediation & aftermath

7-Eleven — investigation	Engaged a forensic security firm, notified law enforcement and states the incident is remediated, with no disruption to operations.
7-Eleven — refused to pay	Declining the ransom is what led ShinyHunters to publish the 9.4 GB archive — consistent with FBI guidance that payment guarantees nothing.
7-Eleven — victim support	Notified individuals (letter signed by CISO Jim Kastle) and offered 24 months of IDX identity-theft protection and CyberScan monitoring; enrollment closed 1 August 2026.
Aftermath — litigation	Putative class actions (Ellison; Choplin) were filed from 1 June 2026 in the Northern District of Texas, alleging 7-Eleven failed to encrypt or redact the data.

REFERENCES

Our Sources

[1] 7-Eleven, Inc. — "Notice of Security Incident", letter of 1 May 2026 signed by CISO Jim Kastle; filed with the Offices of the Maine, Massachusetts and Vermont Attorneys General, 15–16 May 2026.
[2] BleepingComputer — "7-Eleven data breach exposes personal information of 185,000 people". https://www.bleepingcomputer.com/news/security/7-eleven-data-breach-exposes-personal-information-of-185-000-people/
[3] BleepingComputer — "7-Eleven confirms data breach claimed by the ShinyHunters gang". https://www.bleepingcomputer.com/news/security/7-eleven-confirms-data-breach-claimed-by-the-shinyhunters-gang/
[4] Cybersecurity Dive / C-Store Dive — "7-Eleven hit by data breach". https://www.cybersecuritydive.com/news/7-eleven-cyberattack-franchisee-data/820698/
[5] TechCrunch — "7-Eleven data breach affects over 185,000 people's personal data". https://techcrunch.com/2026/05/26/7-eleven-data-breach-affects-over-185000-peoples-personal-data/
[6] Help Net Security — "Personal information of 185,000 people exposed after cyberattack on 7-Eleven". https://www.helpnetsecurity.com/2026/05/26/7-eleven-data-breach-shinyhunters/
[7] Cybernews — "185,000 affected in 7-Eleven data breach linked to ShinyHunters". https://cybernews.com/security/185000-affected-in-7-eleven-data-breach/
[8] Salesforce — "Protecting Your Data: Essential Actions to Secure Experience Cloud Guest User Access", 12 Mar 2026. https://www.salesforce.com/blog/protecting-your-data-essential-actions-to-secure-experience-cloud-guest-user-access/
[9] Salesforce Ben — "Salesforce Hacks 2026: Everything We Know So Far" (7-Eleven on the 18 Apr pay-or-leak list). https://www.salesforceben.com/salesforce-hacks-2026-everything-we-know-so-far/
[10] The Hacker News — "Threat Actors Mass-Scan Salesforce Experience Cloud via Modified AuraInspector Tool", Mar 2026. https://thehackernews.com/2026/03/threat-actors-mass-scan-salesforce.html
[11] FINRA — "Cybersecurity Alert: Salesforce Experience Cloud Security Incident". https://www.finra.org/rules-guidance/guidance/cybersecurity-alert-salesforce-experience-cloud-security-incident
[12] Google Threat Intelligence Group / Mandiant — UNC6040 and UNC6240 campaign reporting. https://cloud.google.com/blog/topics/threat-intelligence
[13] Huntress — "ShinyHunters Threat Actor Profile: TTPs, IoCs & Attacks" (UNC6661 / UNC6671; Drift; Gainsight). https://www.huntress.com/threat-library/threat-actors/shinyhunters
[14] SC Media — Microsoft Defender Security Research on ShinyHunters OAuth abuse, 13 Jul 2026. https://www.scworld.com/brief/shinyhunters-group-exploits-oauth-trust-prompting-microsoft-security-upgrades
[15] Top Class Actions — 7-Eleven class actions (Ellison; Choplin, N.D. Tex., filed from 1 Jun 2026). https://topclassactions.com/lawsuit-settlements/lawsuit-news/7-eleven-class-action-lawsuits-claim-data-breach-exposed-customer-information/
[16] MITRE — CWE https://cwe.mitre.org/ · CAPEC https://capec.mitre.org/ · ATT&CK https://attack.mitre.org/
[17] FIRST / NIST — CVSS v4.0 specification and calculator. https://nvd.nist.gov/vuln-metrics/cvss/v4-calculator
[18] NIST National Vulnerability Database — CVE-2026-1731 (BeyondTrust Remote Support / PRA); CVSS v3.1 base 9.8 Critical, CWE-78; CISA KEV 13 Feb 2026. https://nvd.nist.gov/vuln/detail/CVE-2026-1731
[19] Rapid7 — "CVE-2026-1731: Critical Unauthenticated Remote Code Execution in BeyondTrust Remote Support and Privileged Remote Access", Feb 2026. https://www.rapid7.com/blog/post/etr-cve-2026-1731-critical-unauthenticated-remote-code-execution-rce-beyondtrust-remote-support-rs-privileged-remote-access-pra/
[20] BleepingComputer — "ShinyHunters claims ongoing Salesforce Aura data theft attacks" (sortBy bypass; second bypass claimed), Mar 2026. https://www.bleepingcomputer.com/news/security/shinyhunters-claims-ongoing-salesforce-aura-data-theft-attacks/
[21] Microsoft Security — "Defending SaaS-based applications against ShinyHunters OAuth abuse", 13 Jul 2026. https://www.microsoft.com/en-us/security/blog/2026/07/13/defending-saas-based-applications-against-shinyhunters-oauth-abuse/
[22] RH-ISAC — "ShinyHunters Utilize Public Audit Tool to Scan for Vulnerable Salesforce Aura Instances", Mar 2026. https://rhisac.org/threat-intelligence/shinyhunters-sf-aura/